Case Analysis: Equifax Data Breach

Equifax is a US-based credit reporting agency (CRA), one of three in what is called the Consumer Reporting Agency System. The role of a CRA is to collect consumer data that can be used by businesses, such as employers and creditors, as well as government agencies, in their operations. There is a robust regulatory environment surrounding the CRA system, including oversight and enforcement from agencies like the SEC and FTC, as well as others. The CRA system has a very large role in American society, pulling in data on every consumer in the country and their habits and purchases, and providing them to a variety of business customers. In 2017 an attacker accessed and stole the data of 145.5 million consumers in the US, and more in Canada and the UK. There were immediate responses from all stakeholders, including regulatory action, business customer behavior, and, eventually, monetary compensation from Equifax to affected individuals. The scale of the breach, the regulatory environment in which it occurred, and the aftereffects offer an excellent case study in conflict and cooperation in cybersecurity.

In order to analyze Equifax's internal software engineering and cybersecurity behaviors leading up to and immediately following the breach for this case study, I relied on a variety of data. However, there are a handful of archival documents which are especially important to the analysis. These include the investigations by the US House of Representatives Committee on Oversight and Government Reform, the US Senate Committee on Homeland Security and Governmental Affairs, and the US Government Accountability Office, which issued their final reports in 2018 and 2019. The reports include primary data from interviews with Equifax staff (including the CEO, CISO/CSO, CIO), auditors and forensic analysts within the federal government, staff at Mandiant (the firm that was both hired by Equifax to respond to the breach and mandated by Congress to report on Equifax's response efforts), and government agencies that were customers. These reports are valid sources for so much data because they include e.g. sworn statements from key participants in the case, who could be prosecuted for intentionally misleading the investigators. These individuals (like the former Equifax CEO or CISO) are also not likely to be willing to participate in my study, such as through interviews, so their testimony to the government must serve as primary data for the case study. The data collected in the reports are also extensive. They include valuable information like longitudinal explanations of the software engineering and cybersecurity practices at Equifax as far back as the 1970s, and more recent strategies and organizational behaviors prior to the breach. These are based on testimony from staff within the firm and from their expert vendor, Mandiant. I do not rely solely on this data, and triangulate my analysis with other sources and observations as well. This document was mainly used to analyze the internal workings of the software producer, while the behaviors of the other stakeholders rely on a broader range of sources.

1. Cyber Social Context

The credit reporting agency system is vast in scale. For its end users, it incorporates the data of nearly every adult living in the US, and there is no ability to opt out of it (US House, 2018). The

end users, typically US consumers, are critically impacted by the data collected in their everyday lives, including housing, employment, and banking. CRAs are “woven into the fabric of the country’s business establishment” (Olegario, in Miller, 2003). Business users subscribe to services provided by the agencies, making use of the data for their operations as a “vital aspect of the global financial system … that fuels the economy” (Cuomo et al, 2018;). The credit reporting agencies that collect this information rely on their own complex software implementation to do their business. They collect data from a variety of sources including banks and lending institutions and aggregate the data to create products like credit scores which are used by their business clients. The data they store includes personally identifiable information as well as habits and behaviors that would be valuable to threat actors. These CRAs are highly regulated by multiple government agencies including the Securities and Exchange Commission (SEC), Federal Trade Commission (FTC), Consumer Financial Protection Bureau (CFPB), the courts, and state governments in US. There are additional corresponding agencies in the UK, Canada, and elsewhere. In short, the threat environment is rich with opportunity, the operational environment is considerable with regard to the monetary value of the data, and the regulatory environment is complex.

1.1. Software Producer

Credit reporting started as a way for businesses to get a centralized and controlled method for evaluating potential business partners for lending (Furletti, 2002, US House, 2018). The industry’s operations have expanded to incorporate important aspects of everyday life, supporting a variety of businesses. CRAs offer a suite of products that businesses use to inform their operations based on the data collected about consumers. Equifax is one of three major credit reporting agencies in the US, along with Experian and TransUnion, and boasts credit information on 820 million consumers and 91 million businesses as of the time of the breach (US House, 2018).

1.1.1. Operational Environment

Equifax has been a publicly traded company since 1965. It “gather[s] consumer data, analyze[s] it to create credit scores and detailed reports and then sell[s] the reports to third parties”. Those third parties are businesses that are considering lending money or doing business with individual consumers. Equifax maintains an ecosystem of software to meet their business goals and to meet non-functional requirements to comply with regulations. One such application was the “Automated Consumer Interview System (ACIS), a custom-built internet-facing consumer dispute portal developed in the 1970s”. Equifax built the ACIS software to comply with the Fair Credit and Reporting Act of 1970 and handle customer disputes (US House, 2018).

The ACIS system was built using the Solaris operating system, developed by the “now-defunct company Sun Microsystems” and relied on both open-source and proprietary closed-source software. Equifax used the popular Apache Struts software to make the ACIS system consumer-facing via the internet.

This combination of legacy software intertwined with modern software created a complex operational environment for Equifax.

Meanwhile, the company continued to grow, including a commercial growth strategy that included acquiring eighteen companies from around the world leading up to the breach.

1.1.2. Threat Environment

According to the House investigation, “massive amounts of data equals massive security risks.” As the company grew, so too did its value to prospective threat actors who would seek to compromise their data for illicit gains. There were multiple high profile data breaches of CRAs leading up to 2017, which included Equifax as well as other companies (EPIC, Equifax Data Breach).

In order to mitigate this threat, the cybersecurity teams at Equifax would need to develop a broad internal familiarity with the vulnerabilities that were unique to them. This means that the systems they developed, combined with the value of the data that they stored, warranted “best-in-class protection and cybersecurity practices” for their industry according to the House of Representatives (2018). The investigation detailed the cybersecurity leadership at Equifax, including officers with decades of technology and legal experience who had been hired between 2010 and 2013.

1.1.3. Regulatory Environment

In the US, credit reporting agencies like Equifax operate in a highly regulated environment, both at the federal and state levels, leading to a complex regime to which they must adhere. Federal regulations that grant oversight for CRAs include the Federal Trade Commission Act, Dodd-Frank Act, Fair Credit Reporting Act (FCRA), the Fair and Accurate Transactions Act (FACT), and the Gramm-Leach-Bliley Act, which are enforced by the Federal Trade Commission (FTC) and the Consumer Financial Protection Bureau (CFPB). Because Equifax is a publicly traded company, cybersecurity issues are also overseen by the Securities and Exchange Commission (SEC). At the state level, Equifax also needs to comply with any regulatory requirements set forth by any of 50 states (Cuomo et al, 2018; Schlein & Phillips, 2012; House, 2018). CRAs that operate in other countries must adhere to their regimes as well as international guidelines, such as those provided by the OECD (Villar et al, in Miller, 2003). There is also a bevy of case law that factors into the cybersecurity regulatory regime, as well as other consumer protections, in various US court jurisdictions (Johnson, 2011; Schein & Phillips, 2012; Olegario in Miller, 2003).

In 2017, Equifax was already in the FTC’s crosshairs. In 2012 they were fined for knowingly violating consumer privacy laws, when they improperly sold the data of US consumers who were late on their mortgages. In addition to the fine, Equifax was also required to comply with additional requirements set forth by the FTC (FTC, FTC Settlements Require Equifax to Forfeit Money, 2012).

Equifax also does business in the United Kingdom, and is subject to regulations there, including the independent Financial Conduct Authority (FCA) and the parliamentary Information

Commissioner's Office (ICO), which regulate financial services firms and data privacy, respectively.

The regulatory environment that Equifax operates in is highly challenging. It requires compliance with a multitude of laws, necessitating formidable internal regulations as well. To meet these requirements, there are technical challenges that must be addressed, including security protocols, file integrity monitoring, and network segmentation. Ultimately, they interpret all of the laws and regulations that contribute to the regime to interpret them and apply them as they see fit.

1.2. Users

The users of the software created by Equifax fall into one of two use cases, passive or active. Active users are the customers of Equifax's services, purchasing data about consumers to make operational and financial decisions. The passive users are the consumers about whom Equifax collected data, typically without any affirmative agreement to do so, and without the option to prevent access to the data (US House, 2018).

1.2.1 Operational Environment

Business customers are active users of credit agency services. "Major corporate and government contracts rather than sales to individual consumers create the company's earnings" (US House, 2018). These organizations partner with CRAs like Equifax which "serve as sources of information about consumers' use of credit as reported by those from whom users borrow" and "give businesses insight into a consumer's past behavior" (Furletti, 2002). Money lenders, like banks and credit unions, that are CRA customers may also participate in a "give-to-get" scheme, where they must provide information about their existing customers in order to get information about potential customers (Furletti, 2002). While historically money lenders were the customers of this data, today, other companies also have access to it for heterogeneous practices. For example, to "enable marketers to better deliver the right message to the desired target audience based on consumers' likely interests and economic profiles" (Oracle, Data Directory, 2021; Experian, 2024). In short, CRAs provide data about consumers to any business customer.

Business users benefit from these software services by using them to find and reach their target audiences. Not every staff member has access to this data, so there would be restricted permissions and a hierarchy of users that can use the data for business operations. Consumer users benefit from these services by getting access to products that meet their heterogeneous needs: consumer needs vary widely from individual to individual.

Business customer users also include government agencies, such as the Internal Revenue Service, which used Equifax's identity verification services (US House, 2018).

Consumers are passive users of the CRA technology, automatically supplying their financial information without the option to opt out (US House, 2018; Planet Money, 2018; Lauer, 2017) when they spend money on "retail, travel, auto, and more" (Oracle, 2021). Consumers can also self-report data like their employment and income. All this data, along with other information like

demographics, magazine subscriptions, charity contributions, utility payments, and more, collected from a variety of sources, are available to business customers. They are also aggregated for ease of use, including “buying behaviors, preferences, and characteristics” (Experian, 2021; Experian, 2024; Equifax, 2024; Oracle, 2021). This data is compiled based on credit accounts using Social Security numbers and other identification information (Equifax, What is a Credit Bureau?, 2022).

1.2.2 Threat Environment

According to the US House investigation, “having so much personal information in one place made Equifax a prime target for hackers” and CRAs were the “target[s] of multiple cyberattacks in recent years” (US House, 2018). As such, there is a broad threat of harm to users in this context.

Identity theft, which can occur when personally identifiable information (PII) is leaked can have a negative impact on consumers and their credit history. PII can be leaked by inadequate security for credit data, such as in this case, or from a variety of other intrusions. According to a report from the US Department of Justice, “in 2016, an estimated 26 million persons, or about 10% of all U.S. residents age 16 or older, reported that they had been victims of identity theft during the prior 12 months” (Harrell, 2019). These victims suffered direct monetary losses as well as other financial or legal problems, including higher interest rates on credit cards, denials on loans, utility shutoffs, and even criminal proceedings (Harrell, 2019; Anderson et al, 2008; CALPIRG, 2001; Cheney, 2003). They also experienced emotional distress (Harrell, 2019). This report, based on data from 2016 also indicates that 55% of identity theft victims spent one day or less, and an average of 4 hours, resolving financial and credit problems. By comparison, a 2000 report from the consumer advocacy groups CALPIRG and the Privacy Rights Clearinghouse, reported that it took 55% of victims an average of 44 months to resolve their cases (CALPIRG, 2001). This report also noted that the victims they sampled (n=66) indicated that Equifax was the “hardest one to get in touch with, and the one about which most negative comments were made.”

The DOJ and CALPIRG identity theft reports differ widely in multiple ways. First, there is more than a 15-year difference between the data collected, in which time a lot changed with regard to data privacy and security, particularly surrounding the growth of the internet, social media, and e-commerce. Additionally, the more recent report was released by the federal government, and the earlier by consumer advocacy groups. The DOJ report had a sample size of over 96,000 people, while the CALPIRG report had a sample size of 66. Lastly, while both artifacts used quantitative data, the CALPIRG report also included qualitative data including comments and stories about the victim’s experiences. The DOJ report only included statistical information which hid the perniciousness of the identity theft and seemed to diminish the real impact: it highlighted that 55% were able to solve their problem in a day or less, but that still leaves over 10 million people that had to take more than a day to solve issues arising from the identity theft. However, the DOJ report did include a metric for emotional distress, which was unique. The interests, methodology, and context vary widely between these publications, so it is important to take this into account when analyzing secondary data about the threat environment for victims of identity theft.

1.2.3 Regulatory Environment

The business customer users of the CRA software do not appear frequently in the discussions of the regulatory environment. The data that they accessed may be regulated depending on what industry they are in, such as banking, but the case here is about Equifax itself, which collected, aggregated, and sold the data.

The passive consumer users, however, are highly protected. The regulations introduced in 1.1.3, including legislation and case law going back decades, contribute to regimes that are in place specifically to safeguard consumers. The FTC and CFPB pursue data security violations, enforce consumer financial law, and enforce compliance based on the Fair Credit Recording Act, Dodd-Frank act, and Gramm-Leach-Bliley Act. Private companies are also required by state laws to disclose cybersecurity breaches to users, and possibly by the SEC to investors (US House, 2018). CRAs have also been the subject of lawsuits by consumers since their inception in the 19th century, and consumers were also punished if they "knowingly submitted erroneous financial statements" (Olegario in Miller, 2003).

1.3 Regulators

As discussed, there is a large network of bodies that contribute to the context of credit reporting agency regulation. Their environments have inputs and outputs that have changed drastically over the century and a half since the industry developed, in particular since the advent of software as a key component of CRA operations.

1.3.1 Regulatory Environment

The regulatory environment in the credit reporting system is very active, including the legislative and judicial branches of government in the US, and their counterparts internationally. Although software security is a more recent focus, due to the sensitive nature of the credit reporting system, protecting consumers privacy and rights while supporting businesses economic interests has long been the nexus of regulatory efforts (Furletti, 2002; Olegario in Miller, 2003; Schein & Phillips, 2012; US House, 2018; Johnson, 2011, O'Hara & Hall, 2021). The FCRA, enacted in 1970, was designed specifically because of the concerns arising from the modernizing credit reporting system and its consolidation of sensitive information (Planet Money, 2018; Lauer, 2017). Subsequent laws like the 2003 Fair and Accurate Credit Transactions Act (FACT) include sections to prevent and correct identity theft (Schein & Phillips, 2012). The result is an emergent regime that governs CRA behavior, that has adapted to and been shaped by societal changes including politics, technology, law, and economy. Laws and subsequent regulations have been enacted, resulting in authority being granted to independent agencies to enforce them. Court cases stemming from disputes between parties have led to case law that also contributes to the regulation of CRAs by administrative authorities and sets precedent for future cases. The SEC also participates in regulating the cybersecurity of publicly traded companies like Equifax given the impact of risks and incidents for investors (Wang et al, 2022; Gordon & Silver, 2017).

Outside the US, such as in the UK and Canada, Equifax is regulated by similar laws. The Data Protection Act of 1998 defines eight data protection principles to ensure the lawful processing of data by UK entities and is enforced by the ICO. In Canada, the Personal Information Protection and Electronic Documents Act is enforced by the Privacy Commissioner.

The emergent regime, based on these complex factors, stood as the context for this case study leading to the breach, and throughout the conflict as it unfolded until its conclusion. Regulatory stakeholders acted based on the environment at the time.

1.3.2 Threat Environment

International regulatory stakeholders were familiar with the data security and privacy threats to CRA's data, and had established security measures going as far back as the 1980 OECD guidelines for privacy and transborder personal data flow protection (Villar, in Miller, 2003). In the US, the Fair Credit Reporting Act of 1970 requires CRAs to "adopt reasonable procedures … with regard to the confidentiality" of consumer information (US House, 2018; 15 U.S.C. § 1681(b), 2012).

Software and information technology has become a critical component of CRA operations, and regulatory stakeholders have developed expertise on vulnerabilities, and there is a network of stakeholders that can contribute to monitoring and enforcement actions, both within and outside the government, including industry groups, third party contractors, and other government agencies.

1.3.3 Operational Environment

There are multiple regulatory stakeholders responsible for the credit reporting system, and they are subject to a variety of factors that can impact their operations. In particular are FTC and CFPB, independent agencies that were established by the US Congress. In the UK, Equifax is also subject to regulation by the FCA and ICO. Each organization has mandated jurisdictions and enforcement capabilities that determine their ability to regulate the CRA subjects. They are also impacted by the interests of the parties and politicians that are in power (the CFPB for example, was created by President Obama and cut by President Trump in 2025). There are other inputs, such as the economy, and the human resources available that also impact the operational capabilities of regulators. The courts are also subject to legal precedence, jurisdiction, and the inclinations of the judges that are serving at any given time.

Regulators must take all stakeholders into account in their operations. Enforcement efforts that punish CRA companies for cybersecurity failures too strictly can harm businesses and the economy. In the short term, it could negatively impact the CRA and its clients. In the long term, it could negatively impact the community by dissuading other businesses from operations that they deem too risky. However, lax enforcement action could negatively harm individual consumers and families, and lead to future harms if companies see opportunities to circumvent regulations. Regulatory bodies also have to report to supervisors, such as Congress or a board of directors.

The US Federal Government also provides a collaborative entity that sits within the Department of Homeland Security's National Cybersecurity and Communications Integration Center (NCCIC), the United States Computer Emergency Readiness Team (US-CERT). "US-CERT has partnerships with private sector security vendors, academia, federal agencies, ISACs, state and local governments, and international organizations" to "aggregate and disseminate cybersecurity information intended to help recipients prevent and respond to cyberattacks" (US Senate, 2019).

2. Operating & Precursors

The conditions that preceded the breach of Equifax include their operating activities and overarching practices, as well as those of their users and the regulators. Users relied on Equifax for their day-to-day operations, and Equifax was supposed to follow requirements set by regulators. These operations had inputs and outputs, as well as net effects, that directly led to the breach of Equifax's data. The software that Equifax struggled to maintain was actually their Automated Consumer Interview System (ACIS), a custom-built internet-facing consumer dispute portal developed in the 1970s to comply with the Fair Credit and Reporting Act to handle customer disputes. By 2017, the legacy system behind ACIS was not only outdated, but faced major maintenance and was slated to be updated. In particular, the House investigation shed light on the internal processes of the C-suite leadership and the IT management operations that affected the precursors leading up to the breach.

2.1. Software Producer

In this case, there are clear connections between the business operations of Equifax and the precursors that led to the breach, as well as, ultimately, to the impacts of the breach. The implementation of their software to do business required the constant and ubiquitous collection of data about US and global consumers' "most personal information" (Planet Money, 2018), using software and IT infrastructure going back decades. At the same time, they also had to secure their software to protect this sensitive data, to defend against, and prevent unauthorized intrusions. Simultaneously, they had to comply with strict regulations because of the sensitive nature of their business. The two broad areas of concern are the overarching business practices at Equifax, and the specific management of the ACIS software that was breached.

Business Model

Equifax's business model is to collect, analyze, and sell data about consumers to meet the needs of its customers. While this started as financial information that was sold to businesses for the purposes of credit, it later expanded into new lines of business, specifically, software tools for marketing a wider range of products and services. To meet those business needs, the data being collected also expanded into more types of information about consumers. Starting in the 1970s and 1980s, CRAs like Equifax "entered the database marketing business" meeting their customers' needs with capabilities like demographic segmentation and direct mail campaigns. This growth paralleled the internet revolution and inception of the information economy starting in the 1990s as collecting data about consumers became easier and easier

(Lauer, 2017). The quantity and depth of this data made it valuable for Equifax's business, which meant it also became increasingly valuable for criminals.

Business-wide, their capacity was severely limited due to business process issues with leadership and management, restricting their ability to comply with mandated security requirements and general best practices. At the same time, their software, which had been developed in the 1970s, had become outdated and required business change. Changes required not only immediate critical updates and patches to the software, but also an eventual full system upgrade, replacing the legacy software. Neither of these were properly managed (US House, 2018; US Senate, 2019). These all led to unaddressed failures and weaknesses.

Conflicts between executive leadership also led to capacity issues. Ineffective reporting structures and inattention to cybersecurity by the CEO were identified as inputs that led to the unaddressed failures. According to the report, management "failed to establish clear lines of accountability for developing IT security policies and executing these policies" (US House, 2018).

One example of the weaknesses caused by issues in their business processes was making the ACIS application compliant with the Payment Card Industry (PCI) Data Security Standard (DSS). The IT team explained that they had fallen behind in this implementation, and had they come into compliance, it would have "largely addressed" key security concerns (US House, 2018).

In addition to compliance with existing regulations, Equifax also attempted to influence regulations, at one point spending $250,000 to stop a new consumer privacy act according to Senator Patrick Leahy(Senate Judiciary Hearing, 2017).

Software Management

The Congressional reports go into detail about two of the broad operational security weaknesses at Equifax: their patch management process and their certificate management process. These would have been critical in preparing for, defending against, and possibly preventing the breach altogether. Once an alert had been issued about a vulnerability in a component of their software, Apache Struts, a policy manager should have been accountable for applying and testing the patch and ensuring that it was applied properly. Their certificate management process also lacked appropriate capacity and would have been another tool to alert the team about suspicious traffic. However, the SSL certificates were not properly maintained, representing another unaddressed failure.

Specific to the legacy ACIS environment, the reports analyzed crucial capacity and security issues. For example, documentation and business artifacts regarding the legacy system were ineffective: There was no inventory of the software used in the application, and logs were not kept long enough to identify malicious activity. Capacity to maintain the antiquated software was based on the knowledge of team members that had been there since its implementation. By the time of the breach, this cadre had dwindled to "a couple" of people, according to testimony from the CIO (US House, 2018). The reports identified and analyzed multiple unaddressed technical security failures and weaknesses that existed in spite of the plans to upgrade and patch the

system, such as the lack of separation between different networks, servers, and file systems, which made it easy for attackers to access more data once they had compromised the system.

2.2. Users

As described in the Context in Section 1, there are broadly two classes of user stakeholders for Equifax and other CRAs: business customers and consumers. The business customer users deal directly with Equifax, deploying its software to meet their business goals. The consumers are "passive" users, as their data are the subject of the business relationship between Equifax and its customers. To put it in terms of a hierarchy, the business users have a close relationship with Equifax, putting them higher up on a pyramid. Consumer users sit low on the pyramid, there are more of them, but they are further removed from the CRAs and have limited access to the software system.

2.2.1 Business Customers

The primary users of Equifax's software are businesses, organizations, and government agencies. In his testimony, Equifax CEO Rick Smith stated that only 10% of their business at the time was consumer business (B2C), which means around 90% of their business was with other businesses (B2B) (Senate Judiciary Hearing, 2017). A financial report from the credit agency Experian (a competitor of Equifax) shows that in 2024 around 16% of their business was direct-to-consumer (Experian, 2024). As discussed above, these business customers deploy Equifax's software for a variety of business needs. As of 2024, Equifax identifies products for "Credit Risk, Verification, Identify & Fraud, Workforce Management, Data-driven Marketing" (Equifax Business, 2024). In 2017, their website advertised nearly 200 products and solutions for "business needs" including "Acquire more customers," "manage my workforce," "mitigate risk," "recover debt" and more (Equifax Business, 2017).

According to the US House Report,

> …lenders rely on credit reports and scores when determining whether to grant a loan and the corresponding interest rate. Insurance companies use the information to set policy premiums. Employers may use the information to screen prospective employees for risk of fraud. Utility and telecommunication service providers use the reports to verify the identity of customers and determine down payment requirements for new customers.
>
> Federal agencies use identity verification services … when enrolling new applicants for federal benefits and services. The Internal Revenue Service (IRS), for example, awarded Equifax a $7.25 million contract for taxpayer identity verification and validation services after the 2017 data breach had been publicly announced.

This shows that the CRAs provide a valuable resource for businesses and government agencies. Consumer reports help businesses make informed decisions which can help them succeed and protect them from risk (Furletti, 2002; Lauer, 2017; Hunt, 2002). They can use modern credit reporting software to decide with whom to do business as well as identify markets to grow their business. They can also verify that the people they are doing business with are who they say they are through identity verification. Business customers also include government

agencies, the largest of which were the Internal Revenue Service (IRS), Social Security Administration (SSA), and US Postal Service (USPS). Much like other business customers, these government agencies used Equifax's identity verification services (GAO, 2018).

Business customers not only receive data from CRAs, but also provide it to them. They must "give to get" and "have incentives to report their own experiences with borrowers so as to gain access to other creditors' data in the future" (Furletti, 2002). This gives them access to a "deep and granular view of consumers' lives" from a variety of sources, which is critical to their business model. As of 2017, "Equifax had credit information on 820 million consumers and 91 million businesses" (US House, 2018).

Businesses that deploy these tools come from a variety of industries, and the data that they collect about consumers from Equifax, as well as the data that they provide to Equifax is protected under the same regime that governs Equifax itself. They must secure this information because it includes protected data including PII, which is vulnerable to identity theft. For example, the FTC has compliance requirements for disposal of consumer reports to "protect the privacy of consumer information and reduce the risk of fraud and identity theft" stemming from the GLBA and FACT Act (FTC, Disposing of Consumer Report Information, 2005). Companies that purchase consumer reports must have the capacity to protect this data: their staff must be trained on the rules, and they must provide resources to their technical teams.

2.2.2 Consumer Users

Consumers are the critical component of the CRA system. It is their data that the business customers pay the software producers to aggregate and analyze. It is also the protection of that data that effected the laws and regulations that govern the CRA software producers and their customers. The regimes with which the software producers must comply are designed to protect consumers, who are the citizens of the US and other countries where the companies operate. Consumers also include the government staff responsible for regulation and the employees of the CRA companies who implement the software.

Consumers need this data in their daily lives to meet needs such as housing, employment, and banking. In the interest of "future access to credit," consumers "have an incentive to avoid a default that might become known to other creditors" (Hunt, 2002). As such, people can regularly rely on their credit record as a resource for businesses to trust them in important transactions where there is no prior relationship, such as for mortgages, leases, loans, jobs, childcare, insurance, and more. The companies that use this data can provide other products and services that are valuable for consumers as well, meeting their needs by identifying prospective customers through marketing data provided by CRAs.

However, these reports can also be flawed, leading to negative impacts for consumers. Inaccurate reporting by businesses or adverse events out of the consumer's control can be recorded, affecting their future access to credit. "A lot of times bad credit is the result of bad luck" (Wu, Planet Money, 2018). Moreover, consumer users cannot fully opt-out of this ecosystem and have little control over how this data is collected and secured, leading to the expansive "slurping up" of their "most personal information" (Planet Money, 2018; Lauer, 2017; Office of Elizabeth Warren, 2018). To help remedy the effects of bad credit, especially when it is based on inaccurate information, there are dispute mechanisms mandated by regulators

through the multitude of laws and regulations discussed previously. Protecting the interests of consumers from the harms of poor credit reporting practices has been an important impetus for the rights codified in the law.

Crucially, negative data that puts consumers at risk in the CRA system can arise from identity theft and fraud. Identity theft has indirect and direct costs for consumers. Indirectly, and especially important to this case, are the impacts on their credit reports. Direct costs are the out-of-pocket payments that victims may have to pay resulting from the identity theft. The indirect costs associated with derogatory data on their credit reports can lead to higher interest rates on credit cards, denials on loans, utility shutoffs, and even criminal proceedings (Harrell, 2019; Anderson et al, 2008; CALPIRG, 2001; Cheney, 2003).

2.3. Regulators

As discussed in section 1.3.3., there is a complex regime that emerges from the various governmental and non-governmental bodies that regulate the credit reporting system and its stakeholders. In their regular operations, these bodies practice rulemaking, enforcement, and investigation (based on FTC Authority, 2021) with varying levels of authority and power depending on their influence. There are substantial federal (national) resources that regulate the industry, including the FTC and CFPB in the US. There are also state-level practices from all 50 states and US territories, and supranational organizations as well. CRA stakeholders also participate in self-governance, which can be binding or non-binding, such as PCI-DSS and CDIA Metro 2***. The outputs of all of these regulatory practices result in the net effect of the regime that governs the stakeholders. Additionally, their operational practices, such as rulemaking and influence, have outputs that determine their capacity. For example, rules, created by these agencies and other government offices, can determine how powerful a government agency is: thorough rules can make an agency strong, and fragile rules can make an agency feeble. For example, an agency that can fine violators, resulting in money paid to the regulator and its counterparts, can influence their capabilities.

The FTC is a particularly useful stakeholder for analysis because of the scale and scope of their operations. They perform many of the operations that other regulators do, although most regulators do not have the capacity to do as much as the FTC does. They cover the breadth of operations of most regulators, and while their jurisdiction may be different from other regulators, they present an excellent archetype for analysis of regulatory operations. In this case, they are important because they are an established stakeholder shaping the regulation of CRAs as well as privacy and data security more broadly.

The practice of rulemaking by regulators is ongoing and significant in the credit reporting system. New laws are made, extant ones are updated, and subsequent regulations are established based on those laws. However, changes can take time and are subject to influence from all stakeholders while they are being established. Just a few examples of major changes include the FCRA of 1970, the GLBA of 1999, the Safeguards Rule issued by the FTC in 2003, and the establishment of the CFPB by the Dodd-Frank Act of 2010 (US House, 2018).

Enforcement practices by federal agencies are continuous as well: by 2018, “the FTC has brought over 60 cases against companies for engaging in unfair or deceptive practices by failing to adequately protect consumers’ personal data” (US House, 2018), and over 100 cases for

violations of the FCRA and almost 30 cases for violations of the GLBA (FTC, Privacy & Data Security Update, 2018; US House, 2018). Civil and administrative enforcement activities like these are the FTC's "principal tool … for unlawful behavior, and require the company to take affirmative steps to remediate this behavior. Affirmative steps may include the implementation of a comprehensive data security program or monetary redress to consumers" (US House, 2018).

Another critical factor is that rules are also subject to prior decisions made by the courts. Each enforcement action can impact future enforcement activities, and the regime more broadly. Court decisions seem almost constant, occur in a variety of jurisdictions, implicate heterogenous stakeholders, and result in countless outcomes (Johnson, 2011; US House 2018).

Investigative practices occur before and after violations are identified, as well as after the violations have been remediated with the regulator. Investigation can occur before a violation, resulting in the identification of violations, such as the FTC's 2004 nationwide compliance sweep of financial institutions for violations of the security requirements protecting customers' sensitive personal and financial information (FTC, FTC Enforces GLBA, 2004). Investigation also occurs once a violation has been reported, such as to determine whether to take further action, the scale of the violation, and the appropriate response. This process can involve third parties from other regulators or industry experts, such as auditors or forensic specialists. Following enforcement actions resulting from a violation, regulators may be required to monitor the violating party to make sure they are compliant with rules that they agreed to as a result of the enforcement actions. For example, the FTC sued financial company RealPage, Inc. in 2018 and they were, among other penalties, required to provide a yearly compliance notice to the FTC for 10 years (FTC, Privacy & Data Security Update, 2018; FTC v. RealPage, Inc, Doc 3-1, 2018).

Regulators also engage in activities of influence that impact both their capacity and the emergent regime. Again, the FTC provides an excellent example within the field of consumer privacy, although not directly in the CRA industry. In 2012, the FTC sued and won in landmark cases against Facebook and Google for consumer privacy violations, demonstrating their ability to pursue violators. The Google suit resulted in a $22.5 million civil penalty, an historic fine for the agency at the time (FTC, Google Will Pay, 2012). The Facebook suit led to a consent order, which put penalties in place if Facebook "made misleading statements in the future about consumers' control over the privacy of their personal information." Ultimately, although it occurred after the 2017 Equifax breach, Facebook was fined $5 billion in 2019 for violating this order and resulted in a new order for oversight into their practices (FTC, What the FTC Facebook settlement means, 2019; FTC, FTC Imposes $5 billion Penalty, 2019). These cases are extreme examples of the FTC as a regulator to influence other stakeholders. Although they are not in the consumer reporting field, they do signal to other software companies, as well as users and other regulatory bodies, that the FTC has the capability, including authority, funding, intelligence, and knowledge to enforce rules. Their operations also shape the regime, establishing precedence for future regulatory operations.

3.Incident & Impact

Attackers breached Equifax and remained undetected for 76 days starting in May 2017. The attackers used a vulnerability that was first detected by the Apache Software Foundation in February 2017 and disclosed by them publicly on March 7. NIST's National Vulnerability Database indicated that the complexity of compromising the vulnerability was low, and the potential damage was high, and US-CERT also notified companies like Equifax of the vulnerability. In late July an Equifax cybersecurity team detected suspicious behavior and began the process of containing and eradicating the vulnerability. Starting in August, Equifax began investigating the impacts of the breach and preparing for their next steps. The incident refers to the span of time between when hackers exploited the vulnerability and when Equifax was able to eradicate it. The incident compromised the data of 148 million users, exposing their protected PII to nefarious actors. The incident has multiple impacts during and after the incident on the company, its users, and on regulators.

3.1. Software Producer

3.1.1. Incident

As discussed in Section 2, Equifax's operations effected a variety of precursors that exposed a vulnerability in their software. Specifically, there were unaddressed failures and weaknesses in the legacy systems supporting their internet-facing ACIS environment, including two web servers and two application servers. These servers relied on a software module called Apache Struts, which needed to be patched after a critical vulnerability was discovered and publicized in Spring 2017. The vulnerability was identified as CVE-2017-5638, was published by the National Vulnerability Database on March 11, 2017. Companies including Equifax were informed of its existence (US House, 2018). Two months later, on May 13th, the incident began when hackers were able to exploit the exposed vulnerability. The attackers were able to query databases in the system, target valuable data, and ultimately exfiltrate it.

During the incident, the attackers were also able to "move laterally" and access other databases unrelated to ACIS where the breach began. This is because the ACIS software was not segmented to prevent such behavior. The system suffered from other flaws (SQL Injection and Direct Object Reference attacks) that allowed the attackers to not only view the data, but also add software modules to the server which were then used to retrieve the data they identified. The attack went unnoticed for an extended period because another failure, expired credentials (for SSL certificates), prohibited Equifax's IT security team from monitoring traffic in the ACIS system.

After being out of date since January 2016 (19 months), the credentials were finally renewed and uploaded on July 29, 2017. At this point, Equifax's IT was able to inspect traffic and immediately detected suspicious behavior, analysis indicated that it consisted of "requests from an IP address originating in China" (US House, pp 35, 2018). After the suspicious traffic was detected, vulnerability testing was conducted, and the SQL injection vulnerability was also identified. At this point, on July 30, the security team "decided to shut down the ACIS web portal for emergency maintenance" eradicating the vulnerabilities and effectively ending the attack (US House, 2018).

The attackers had access to the compromised systems and data for a total of 76 days until the breach was identified. The data the attackers identified and retrieved (compromised) included personally identifiable information about consumers, including names, dates of birth, social security numbers, and more (US House, pp 53, 2018). This data can be used for crime, espionage, activism, or other efforts.

3.1.2. Impact

The most immediate impact to Equifax was the initiation of Project Sierra, which was their endeavor to respond and recover from the attack. Eventually, the attack would have direct costs of over $1.38 billion and could be over $7 billion when considering indirect costs (Consumer Actions In re: Equifax Inc, Document 1029, 17 March 2020). Direct costs include a fund of $380.5 million for the damages to members of the class action lawsuit, and millions more depending on class members (users whose data was compromised) participation. Indirect costs include the human and capital resources that Equifax had to commit in order to respond to the aftereffects of the incident. After they disclosed the incident, “Equifax’s stock price fell 25 percent in the first week, wiping out $6 billion in market revenue” (US House, pp 44, 2018).

Another major impact was the shut down of the ACIS portal, which was for handling customer complaints. This meant that customers were unable to file their complaints until the legacy software was fully updated or replaced.

3.2. Users

All in all, the attackers gained unauthorized access to the data of 148 million individual users. Critically, this was primarily PII, including names, dates of birth, social security numbers, addresses, driver’s license numbers, phone numbers, email addresses, payment card numbers, and more (US House, pp 53, 2018). Together, these data put individuals at risk for a variety of harms like identity theft. However, not all users suffered the same exposure. For example, unauthorized access to payment card (credit card) number and expiration date data was limited to 209,000. And email addresses, which did not include login credentials, amounted to 1.8 million. Thus, not all users suffered the same consequences of the breach. However, the name, date of birth, and social security numbers were still compromised for over 145 million people (US House, 2018).

In the UK, an additional 15.2 million consumers were affected by the breach, including the sensitive data of 693,665 users (McCrank, 2017). In Canada, 19,000 people’s data was compromised, “almost all of whom had their social insurance number, along with other accompanying identifiers, compromised” (PIPEDA Findings, 2019).

The immediate impact on business customers is less clear. Ultimately, they trade information about the consumer users with Equifax. It is possible that they may have sought other vendors to provide these services if they no longer trusted Equifax.

The harms to users, both consumers and business customers, as a result of this breach, is unknown. There is not a way to determine whether the data compromised in the Equifax breach led directly to out-of-pocket costs for victims. Eventually, however, individuals were eligible to receive up to $125 from the settlement, as well as out-of-pocket expenses. Research indicates

that there was an average loss of $930 per victim of identity theft in 2018, and victims may also suffer negative impacts on their health and well-being (Maher & Hayes, 2024).

3.3. Regulators

The immediate impact of this breach on regulators is limited. The government bodies responsible for supporting cybersecurity had publicized the vulnerability in their typical operations. Nongovernmental bodies that contribute to financial data protection would face their challenges later. Eventually, the executive, legislative, and judicial branches of the federal government would get involved. However, there was no immediate impact until Equifax moved on to the responding and recovering phase.

4. Responding & Recovering

The responding and recovering phase for this case is immense and went on for years, compounding complex action-interactions. It necessitated the involvement of stakeholders from every corner of society: millions of users, multiple government bodies, elected officials and bureaucrats, senior leadership and middle management within Equifax, and a network of experts in cybersecurity and law representing all sides. This phase began the moment Equifax eradicated the vulnerability in July 2017 and concluded in January 2024 when the deadline passed for users to make claims for damages, as ordered by the courts in the US.

The strategies and activities of this phase are detailed down to their minutiae in highly reliable documentation, particularly the US House of Representatives Committee on Oversight & Government Reform report from 2018, as well as news publications, court documents, public statements, and official communications from Equifax.

4.1 Software Producer

On July 30, 2017, Equifax shut down its breached ACIS system and began the process of responding to and recovering from the incident. Their first step was escalating the details about the breach known at that time to senior management in the C-suite. The following day they initiated “Project Sierra,” allocating *ad hoc* resources to correct the net effects of the incident. Their correction activities quickly included forming a network with cybersecurity firm Mandiant, the FBI, and outside legal counsel (US House, pp 40, 2018). The response from both the regulatory and user stakeholders was swift and had major impacts on Equifax’s response & recovery efforts. They started the process of complying with regulatory requirements, specifically disclosure, preparing statements and resources for the affected users on September 7th. On September 14th, one week after the disclosure, the House of Representatives launched its investigation. Their strategies also included posturing to protect their interests when they made the incident public, such as by carefully wording the disclosure prior to its release.

In strategies of both posturing and compensation, Equifax initiated another campaign of activities, dubbed “Project Sparta.” They established a website and call centers so that users

could find out whether they had been affected and “facilitate enrollment in credit monitoring and identity theft protection services” (US House, pp 42, 2018). The Project Sparta team dedicated ad hoc resources including dozens of staff and was led by senior leadership. On September 7th, Equifax publicly announced the cybersecurity incident, directed consumers to the ad hoc website (equifaxsecurity2017.com), and promised one year of free services to victims of the breach as compensation. Initially, it seems as though they were not prepared for the scale of the incident: this site, as well as the call centers, were overwhelmed. Their systems were not ready to handle the influx of requests to either channel (US House, 2018). A fake website was even set up to take advantage of consumers, leading to further confusion and harm (Warren, 2018).

To recover from the breach, Equifax also had to correct the issues that led to the breach in the first place. The recommendations for these changes to business processes came from their external partner Mandiant and included eleven overarching technical and process improvements. These changes began in early October. Mandiant and Equifax confirmed to regulators in August 2018 that these recommendations had been implemented (US House, pp 85-86, 2018).

Soon, Equifax also began its arduous compliance activities, specifically, reporting to regulators’ investigations. Between October and December of 2017, then-Equifax CEO Richard Smith testified before three Senate Committees and two House Committees. Other senior leaders were also interviewed as part of the House committee on Government Oversight. The Government Accountability Office conducted their own investigation which included visits to Equifax offices and interviews (GAO, 2018). Email communication and other business artifacts were also collected from Equifax and Mandiant as evidence in these investigations, which would have required effort to obtain. Smith’s official statements and testimonies both admitted guilt and helped posture the company to protect its interests in the future. He acknowledged failures and highlighted efforts to correct them, and pushed their compensation for users that were affected. Equifax also disclosed details about the breach to the SEC in their regular filings, including the May 8, 2018 report (8-K) which detailed the scope of the breach in terms of the affected users, and the annual report (10-K) on March 1, 2018, which included information about their remediation efforts (Equifax settlement order, 2020; Equifax 8-K, 2018; US House, 2018).

Compliance activities continued, and starting in 2018 Equifax was issued Consent Orders from multiple state and federal agencies including the FTC, CFPB, State of New York, State of California, and others. These required Equifax to pay fines, compensate affected users, remediate problems, and report on their compliance to these regulators.

4.2 Regulators

The response phase by regulators was prompt, broad, and vehement. A week after the breach was disclosed, the FTC, FBI, multiple Congressional Committees, and multiple States opened or joined investigations and called for hearings and reports. Bills targeting Equifax were even introduced to Congress. Consumer advocacy groups also chimed in, calling for compensation. That same week, Equifax CEO Richard Smith agreed to testify before Congress within a month. At this early stage, these activities supported nearly the full gamut of response strategies for regulators: posturing, correcting, and adhering. Only compensating remained, and that came

later. The ongoing enforcement by regulators ultimately resulted in correction and compensation mandates by legislative, executive, and judicial bodies.

The mix of these response activities come from multiple regulatory bodies, can support multiple strategies, and vary in their effects. A statement by a legislator may be passionate, but not lead to any real change. A lawsuit from an individual could expand into a class action case. Below I will analyze regulators' activities and how they support their strategies to respond to the incident.

4.2.1. Posturing

Posturing activities took place especially early in the response phase following the breach. These activities could turn into further strategies but could also just remain as posturing if they were not followed up with further action. Their efforts could have ulterior motives as well, attempting to influence other situations such as elections. However, even the posturing could have an impact on the software producer and the users with respect to the incident.

The purest examples of posturing activities are statements made. Following the disclosure of the breach there were numerous statements made by regulatory bodies. Senator Chuck Schumer denounced Equifax in the Congressional Record, calling not only for an investigation to "the murky bottom," but also demanding five specific actions by Equifax, and calling for the resignation of the CEO and board of directors if they do not submit (Volz & Heavey, 2017; Schumer, 163 Cong Rec S 5711, 2017). According to news reports, the FTC spokesperson confirmed in advance that they would be investigating the breach, which is not typical (Volz & Heavy, 2017; Fung & Shaban, 2017). Senator Sherrod Brown leveraged the breach in session to promote his proposed amendment to existing legislation, stating that it would protect military servicemembers from negative impacts of the breach. He made this statement during his allotted time debating the unrelated nomination of the Deputy Secretary of Housing and Urban Development (Brown, 163 Cong Rec S 5727, 2017). Representative Ted Lieu stated that he was drafting two bills in response to the Equifax hack (Fung & Shaban, 2017). According to the Congressional Record, Lieu did not introduce a bill, nor did he appear as a co-sponsor of the single bill that was introduced to the House. Clearly, these statements have nothing near the force of law, and they may not even result in further action, but they may influence behaviors by all stakeholders.

A more complex example of posturing is constructing jurisdiction. This means that regulators prepare to amend the regime that regulates the software producer, although it may not come to fruition. This amounts to posturing particularly when it is reasonable to assume that their efforts are not likely to succeed. A success would entail correction or enforcement actions that come later. However, the activity does require resources and is visible to all stakeholders, so it can have an impact even if it fails. For example, two bills were introduced to Congress within a week in response to the breach, including one in the House of Representatives and one in the Senate. The House bill was an amendment to the Fair Credit Reporting Reform Act (FCRA), introduced by Maxine Waters with 34 cosponsors, and it was referred to a Committee where it died (HR 3755, 2017). The Senate bill, the Freedom from Equifax Exploitation Act, also an amendment to the FCRA, was introduced by Elizabeth Warren with 11 cosponsors, it was referred to a Committee where it died (S 1816, 2017). Neither Waters nor Warren seemed to

make any public statements about the breach, and instead focused on constructing jurisdiction through proposed legislation as a means of posturing.

The last activity that supports posturing as a strategy is forming and managing networks. Regulators can combine resources with other parties to bolster their response and recovery actions. This might include other regulatory bodies, technical experts, legal experts, advocacy groups, and more. While forming networks might be done privately, the publicly visible activities are the one that can be observed for study and have the most impact on posturing specifically as they can be observed by the other stakeholders. In this case, networks formed by regulators abound. The House Committee on Energy and Commerce submitted questions to the Apache® Software Foundation (ASF) ahead of their hearings with the Equifax CEO. ASF posted their response publicly on their blog (US House, 2018; Sally Khudairi, 2017). The Government Accountability Office (GAO) conducted their study into federal government customers of Equifax software at the behest of Congressional Requestors. The court's decision in the federal class action lawsuit against Equifax included Supplemental Declarations (sworn statements) from third party legal experts (Equifax Litigation, Document 956, Thrash, 2020). Even Mandiant, the firm hired by Equifax to investigate their breach, became part of the regulatory network. The US House Committee on Oversight and Government Reform (it is their report that is heavily relied upon in this analysis) relied on Mandiant not only to provide essential information during their investigation, but also confirm that Equifax had made critical changes necessary to remediate their cybersecurity failures later on(US House, 2018).

Congress also postured by forming networks with experts in the field, specifically by bringing them in to testify. The Committee on Banking, Housing, and Urban Affairs brought a legal scholar, a financial technology analyst, the president of the Electronic Privacy Information Center, and cybersecurity analyst from the Congressional Research service to testify about the Equifax breach (S.Hrg. 115-132 – Consumer Data Security and the Credit Bureaus, 10/17/2017; S.Hrg. 115-95, Examining the Fintech Landscape, 9/12/2017).

4.2.2. Adhering & Complying

The multiple regulatory bodies discussed so far all have their own mandates, different foundational principles that contribute to the regime that governs the stakeholders in this case. For regulators, the compliance activities that they undertake are implementing their mandate. This case, each body implemented their mandate in different ways.

Initially, regulators were passive, receiving the notification from Equifax about the breach. The regulators that received the notification formally included all 50 states per their individual breach notification requirements. Immediately thereafter, federal agencies and congressional committees initiated investigations. Additionally, the US-CERT warned consumers about possible scams arising from the breach (US House, pp 44, 2018).

Based on those investigations, federal agencies like the FTC filed complaints against Equifax, exercising their right, and duty, to sue companies. Additionally, law suits were filed by individuals, who also have a right to sue, and the courts implemented their mandate in hearing

those cases, eventually finding in favor of the class action lawsuit. In the UK and Canada, regulators began investigations into the breach.

There does not seem to be any evidence that third parties that help regulate the consumer reporting system, such as the CDIA, took any action against Equifax for the breach.

4.2.3. Correcting

Regulatory agencies took many actions to correct the operations and precursors that led to the breach. These activities primarily took the form of enforcement, and each body has its own enforcement capacity and capabilities. Activities also include amending the regime to prevent similar issues from arising in the future, and to set precedent for how to respond when they do.

In the legislature, the multitude of investigations, including hearings with the Equifax CEO is part of their enforcement capacity. They brought in the most senior leader to account for the behavior of the company. While there was new legislation introduced to amend the existing regime, no changes to the law were made.

Federal executive agencies also performed enforcement activities, including their own investigations, lawsuits, and penalties. The CFPB, for example, levied a penalty of $100 million for the violations, and State agencies also engaged in similar activities. These agencies also amended the regime in a narrow way by introducing new controls and reporting requirements for Equifax going forward so that they could monitor the correction activities by Equifax. These were meant to punish Equifax and correct their behavior so that an incident like this did not happen again (FTC, Equifax to pay $575 million, 2019). The SEC also sent a comment letter in response to the Equifax's annual filing requesting that they "expand [their] disclosure of the 2017 cybersecurity incident" to which Equifax responded with a single paragraph quoted from other filings (SEC Comment Letter, 2018; Equifax response to comment letter, 2018).

The United Kingdom also punished Equifax through two fines for compromising the data of its citizens. First in 2018, the parliamentary Information Commissioner's Office (ICO) fined them £500,000. Then, in 2023, the Financial Conduct Authority (FCA), a non-governmental regulatory body fined Equifax £11,164,400 after a series of complex calculations based on the company's income, the "seriousness of the breach" and Equifax's "mitigating and aggravating" actions during and after the breach (FCA, Financial watchdog fines, 2023; FCA, Final Notice, 2023; ICO, Monetary Penalty Notice, 2023). Both fines are considered punishment (correction activities, not compensation) because they do not compensate users for the harm. Instead, they are levied to force Equifax to comply in the future, and the money goes to the organizations as revenue to support their capacity.

In 2019, the Canadian Office of the Privacy Commissioner found that following the breach, Equifax had done enough to prevent a future incident, and required them to be monitored by Canadian authorities for six years. No other penalties were imposed.

The results of these correction strategies are discussed in the Outcomes section.

4.2.4. Compensating

Regulators pursued compensation for the users that were negatively affected by the breach. Not all regulatory bodies have the capacity or jurisdiction to do this, so it was primarily the FTC, CFPB, state governments, and the courts that pursued payments and services to be provided by Equifax. Following the various procedures, investigations, and lawsuits by government agencies, Equifax was mandated to compensate consumers, paying money and providing services to help protect them from future harm.

The class action lawsuit filed by affected users was also upheld in federal court, which also mandated that compensation be paid. In that order, the court also required Equifax bear the costs associated with filing the lawsuit by the class, and the cost of administering the payouts (Equifaxbreachsettlement.com, accessed 12 December 2024).

4.3. Users

Users began their response and recovery phase once the breach was disclosed by Equifax. They were first able to collect compensation and correct business problems through the services provided by the Equifax breach website, finding out if their data had been compromised and signing up for credit monitoring and identity theft protection services. Later, users were also able to collect compensation from the FTC settlement and class action lawsuits.

Users, as well as advocacy groups representing them, began posturing through making statements and forming networks. An example of these efforts are the public comments submitted through Regulations.gov, a portal for citizens to reach out to federal agencies like the FTC and CFPB. Starting after the breach disclosure, through the end of 2018, at least 46 comments were submitted referencing the breach. These comments have the dual impact of acting as public statements as well as attempting to form a network with the regulators, by contributing to their enforcement activities. As recently as 2024, requests were being made by individuals for the CFPB to regulate the credit reporting industry due to the 2017 breach (CFPB-2024-0012-0001, 2024, accessed December 17, 2024).

User advocacy groups like the Electronic Frontier Foundation (EFF) and the US Public Interest Research Group (US PIRG) also made statements on behalf of consumers, advocating for compensation and corrections to the law, as well as criticizing regulatory actions as ineffective (US PIRG, 2018; EFF, 2019).

In 2018 a 559-page class action lawsuit was also filed against Equifax by 96 individuals (class representatives) and 13 lawyers, for 99 counts under state and federal law, in the US District Court for the Northern District of Georgia. Given the importance of this litigation, in response, Equifax made a concerted effort to protect their business interests through appeals, statements, objections, and overall attempts to construct the jurisdiction of the case in their favor. They also formed a network of supporters to help object to the lawsuit, including *amicus curiae* briefs and even objections from affected individuals, although they may not have all been from actual affected individuals (Klonoff, 2019). The plaintiffs won the case, adding to the regime that regulated Equifax. To comply with the regime, the court ordered Equifax to pay compensation of

at least “$380,500,000 into a Consumer Restitution Fund,” including cash payments, credit monitoring services, restoration services, and all fees related to administering the fund. This amounted to about $125 per person who who filed a claim (Equifaxbreachsettlement.com, accessed 12 December 2024). This settlement process ended in January 2024 following the close of the deadline for extended claims.

Other corrections by individual users to resolve their business and software problems would have been for them to use competitor credit reporting tools and services to replace those provided by Equifax. However, there are a few caveats to this. First, individual users (consumers) are unable to extricate themselves from the credit reporting industry, or Equifax’s software, as discussed in the Context section. Second, if they chose not to use Equifax’s credit monitoring and identity theft services, provided for free as compensation, then they would likely incur costs to use a competitor’s services. Using a competitor’s services may have been an option for some users, so as not to further rely on Equifax. However, for others it may have been a burden, requiring them to find, subscribe, and pay for those services.

Business customers of Equifax responded as well. The best examples of these responses available are from the government agencies, like the IRS, SSA, and USPS that used Equifax’s services. They are major customers of Equifax and have resources that many customers would not have, but are still useful examples of activities that support the response strategy of correcting. According to the GAO, which reported on these responses, these customers identified affected individuals, performed independent assessments of Equifax security controls, modified contracts, communicated with the public and affected individuals, made changes to “identity-proofing procedures,” and there is an example of a canceled short-term contract with the IRS (GAO, 2018).

I conducted a thorough search of publicly available information about similar activities by financial institutions and other business customers of Equifax, but found no data.

5. Outcomes

5.1 Software Producer

5.1.1. Costs

The cost estimates from At-Bay and eRiskHub for the 2017 Equifax data breach range from $660 million to $868m. These estimates include, *inter alia*, between $236m and $400m in fines, $88m for a call center, and $98m for credit monitoring services.

The lawsuits by individuals (and their class action), the FTC, state agencies, and others, culminated in a final settlement of a minimum of $380.5 million paid to consumers, and up to $505.5 million depending on the result of the claims made. Additionally, Equifax paid $175m to 48 states, the District of Columbia and Puerto Rico, and another $100 million fine to the CFPB (FTC, Equifax to pay, 2019; Equifaxbreachsettlement.com). There were additional fines in the UK totaling over $14m dollars as well (based on conversions from xe.com for 2018-2024 and

the fines totaling £11,664,400). Assuming the entire US settlement was paid to consumers, this reaches nearly $795m in direct costs just for compensation and penalties.

The consent order from the class action suit also indicates the costs of remediation. Equifax agreed to "spend a minimum of $1 billion for data security and related technology over five years" (Equifax Litigation, Final Approval of Settlement, 2020). In 2020, Equifax stated that the incident cost them nearly $2 billion at that point (Meltzer, BizJournals, 2020).

Equifax stock price also went down following the announcement of the breach. The breach was publicized by Equifax on September 7, 2017, with a closing share price of $142.72. A week later, on September 14, the price had tumbled to $96.66, losing over 40% of its value (Yahoo Finance, accessed Feb 2025).

5.1.2. Transformations

There were manifold transformations that were outcomes of Equifax's response and recovery actions. Because of the high profile of this case, these changes were made public as part of the investigations and reported to regulators as required by enforcement actions. While some changes at the highest levels are made public for large companies like Equifax, the mid-level changes are not usually available for analysis. In this case, we can see that executive and middle-management personnel were fired or changed roles, new security processes were implemented, processes that had wavered were bolstered, new networks were formed with external experts, software was upgraded, among other things, according to the US House investigation (US House, 2018).

5.1.3. Preservation

Equifax was able to preserve certain interests despite the breach. For example, they are still in business, this event didn't cause them to fail. Similarly, while their business customers may have conducted some investigations, like the IRS and SSA did, those customers continued to use Equifax's software in some capacity (GAO, 2018).

5.2 Regulators

The response & recovery actions of regulators from multiple jurisdictions resulted in multiple outcomes, setting the stage for years of future work.

5.2.1. Remedies

Regulators, including courts, agencies, and legislators effected a few remedies. First, the courts supported the claims of both the individuals' and the government agencies, resulting in a settlement fund to be paid directly to harmed individuals, and fines paid to regulatory bodies. Second, the courts supported ongoing enforcement actions, specifically monitoring Equifax's data security practices going forward (Equifax Litigation, Final Approval of Settlement, 2020).

Additionally, regulators (FTC, CFPB, ICO, FCA) also fined Equifax for violating the law, resulting in revenue for their agencies to conduct their operations.

5.2.2. Costs

The regulatory response was vast, tapping into the capacity of a variety of regulatory stakeholders. Human resources were dedicated by lawyers, technologists, bureaucrats, judges, elected officials, etc., inside and outside the government. Their efforts would have incurred further costs including things like travel and materials. Agencies that levied fines against Equifax may have been able to recover some of these costs.

5.2.3. Transformations

Despite the scale of this case, there do not seem to be many transformations to the regime that preceded the incident. Regulatory bodies from across the spectrum followed their existing mandate and operated well within their jurisdictions. National and state agencies pursued investigative and enforcement actions in accordance with prior incidents. Elected officials investigated and created public documentation due to the sensitive nature of the data for consumers. So, there were no new enforcement approaches to speak of. The courts ruled in favor of the plaintiffs, but the decision was not seen as radical, although the monetary damages were substantial. As such, the case law was transformed only insofar as it added another example of continuity.

The only transformation to the regime was specific to Equifax, in that there were a new set of rules specific to them, such as reporting requirements, business process changes, and monetary compensation.

5.2.4. Preservation

Regulators preserved much through their response and recovery actions. As described in Section 4.2, they pursued the offending software producer very visibly in a variety of ways. The net effects of these actions are that their interests, as well as those of the other stakeholders, were largely preserved.

Regulators were able to follow best practices given their capacity and deliver results that can be seen as favorable to their stakeholders. For example, elected officials were able to hold public hearings to hold Equifax accountable for their failure, which is validating for their voters. Enforcement agencies were able to sue, and eventually won a substantial settlement which they publicized widely, demonstrating their ability to achieve their mandate. Individuals were also able to sue (with representation) and also won in court, giving consumers a judicial victory. Equifax, while it incurred significant costs, was still able to operate going forward, much the same as it had done before, showing that while regulatory enforcement can be harsh, it can also be fair.

In this case, regulators were able to show that the regime was working and that its summative components should be preserved.

5.3 Users

5.3.1. Remedies

Users were compensated via a settlement fund, following the class action lawsuit by individuals, and the lawsuit brought by the FTC, CFPB, and state governments. The settlement included a minimum of $380.5 million payment by Equifax into a Consumer Restitution fund, which would pay cash to Settlement Class Members (victims of the breach) for Out-of-Pocket Losses, Time Spent, and Credit Monitoring Services, among other things. This fund also included payment to the lawyers that represented the case, which amounted to close to $80 million, over 20% of the fund. There was also an additional $125 million for Out-of-Pocket losses, if the initial fund was used up. Typical payments were up to $125 for affected individuals (Equifax FAQ).

Individual users were also able to take advantage of identity theft protection services provided by Equifax for both compensation and preventative measures against future harm.

Business customers, specifically the IRS, SSA, and USPS, following their investigation required Equifax to remediate a few issues. First, they were required to address some “lower-level technical concerns.” Additionally, the IRS and SSA modified contracts to require them in case of future breaches, as they were not notified separately from the public announcement (GAO, 2018). It is possible that other large clients of Equifax were able to negotiate similar remedies, but smaller businesses would be unlikely to be able to customize their agreements without sufficient leverage.

5.3.2. Costs

For consumer users, who were passive users of Equifax’s software, the costs of recovering from the breach are complex, but limited. Some users may have invested resources (time, money) to protect themselves from possible identity theft resulting from the breach. They may have trained themselves on data privacy and security or purchased new software to protect themselves from future harms. However, it does not seem like this was a common course of action. Even in 2023, as much as 50% of US adults indicate that they have not used or heard of identity theft protection software, and an additional 17% planned to use it in the future. Furthermore, in terms of how much adults would be willing to pay for ID protection, 44% of people said that they would not pay anything, and 30% said they would pay less than $15 per month. Only 11% of respondents indicated that they would pay more than $15, while the remainder said that they had never heard of it (Goodwin, 2023).

Ultimately, users that were able to receive compensation stemming from the settlement still paid the lawyers that represented them around $80 million dollars in the aggregate for the right to be remedied financially.

Business customers may have also spent money to respond and recover from the incident. The federal agency customers launched their own investigations, requiring time and money. Including, for example, visiting the offices of Equifax in Georgia. Other business customers may have privately sought other vendors for the services that Equifax provided.

5.3.3. Transformations

In response to the breach, it is not likely that many consumer users made any noticeable changes to their business, security, or use processes. However, new networks may have emerged, such as those people that participated in the litigation, and advocacy groups that may have seen growth in interest in their cause because of the publicity of the breach.

Business customers may have addressed security concerns like the government agencies did, conducting their own investigations and introducing new processes for future cybersecurity incidents with their vendors.

5.3.4. Preservation

Among users, both business and consumer, there is a strong indication that there was little or no change as a result of the recovery and response phase. The operations that preceded the incident appear more likely to be preserved than changed.

6. Aftermath

As discussed in Section 5, there were no extreme changes that resulted from this case. The principal outcomes were mostly preservation of the context and operations that preceded the incident. The transformations that occurred were predominantly narrow in scope, limited to almost exclusively to Equifax.

However, the scope of this case is immense, incorporating an historic number of stakeholders and a substantial amount of activity, all of which was very visible to the public. So, while the consequences do not amount to systemic revision or change, this could be considered disruption. In this situation, disruption means, counterintuitively, that “all forces of change … work to preserve rather than overthrow the existing structure” (Kello, 2018).